

Engineering Handbook – Volume 08

Security & Multi-Tenant Architecture (Version 1.0)

Purpose

This volume defines the security model and tenant isolation strategy for the Industrial IoT SaaS platform.

Authentication

The backend uses JWT bearer authentication. User credentials are stored as bcrypt password hashes. Every protected endpoint validates the access token before processing requests.

Authorization

Future versions will implement Role-Based Access Control (RBAC) with permissions at Company, Department, Machine and Feature level.

Tenant Isolation

Every business entity belongs to a Company (tenant). Queries, APIs and background services must never expose records belonging to another tenant.

Password Policy

Passwords should meet configurable complexity rules. Password reset, rotation and account lockout should be supported in future releases.

API Security

All production APIs must use HTTPS. Input validation, request size limits, structured error responses and audit logging are mandatory.

Secrets Management

Database credentials, JWT secrets, API keys and SMTP credentials must be supplied through environment variables or a secrets manager and never committed to source control.

Audit Logging

Authentication events, configuration changes, deployment activities and privileged operations should be written to immutable audit logs.

Industrial Security

Edge gateways should authenticate with unique device credentials. Device provisioning, certificate rotation and communication integrity checks are recommended.

Security Roadmap

Future enhancements include MFA, OAuth integration, refresh tokens, API rate limiting, intrusion detection, encrypted backups and centralized identity management.

Security Checklist

- Enforce HTTPS
- Hash passwords with bcrypt
- Validate JWT on every protected endpoint
- Isolate tenant data
- Store secrets outside source code
- Log authentication events
- Backup and encrypt databases
- Review dependencies regularly
- Keep Docker images updated
- Apply least-privilege principles